

SASD

Pflichtenheft

Desktop Secret Manager mit HTTPS/TLS-Zertifikatsverwaltung

Pflichtenheft: SASD Desktop Secret Manager

Überarbeitete Umsetzungs- und Ausführungsspezifikation passend zum konsolidierten Lastenheft

Dokumenttyp	Pflichtenheft, überarbeitete Fassung
Projekt	SASD Desktop Secret Manager / lokaler Passwort- und Secret-Manager
Dokumentziel	Konkrete Umsetzungs-, Test- und Abnahmespezifikation passend zum überarbeiteten Lastenheft
Adressaten	Auftraggeber, Entwicklung, Architektur, Test, Dokumentation und spätere Release-Planung
Technologierahmen	C# / .NET 8 / WinForms; Schichten Domain, Application, Security, Storage, Interop, UI, Tests
Status	Arbeits- und Ausführungsgrundlage mit dokumentierten V1-, V1.x-, V2- und V3-Abgrenzungen
Stand	18.05.2026
Leitgedanke. Dieses Pflichtenheft beschreibt nicht nur den zu liefernden Funktionsumfang, sondern auch bewusste Grenzen. Es nimmt die Verwaltung von HTTPS/TLS-Zertifikaten ausdrücklich auf, ohne daraus vorschnell eine vollständige PKI- oder ACME-Plattform zu machen.	

Inhaltsübersicht

1. Management Summary
2. 1. Dokumentzweck, Quellenbasis und Verbindlichkeit
3. 2. Zielsystem, Einsatzkontext und bewusste Abgrenzung
4. 3. Release- und Lieferstrategie
5. 4. Technologischer Lösungsrahmen und Projektstruktur
6. 5. Zielarchitektur und Schichtenverantwortung
7. 6. Fachliches Datenmodell und Persistenzmodell
8. 7. Secret-Typen und Feldspezifikationen
9. 8. HTTPS/TLS-Zertifikatsverwaltung
10. 9. Bedien- und UI-Konzept
11. 10. Sicherheitskonzept und Schutzgrenzen
12. 11. Vault-Dateiformat, Backups und Restore
13. 12. Mehrtresor-, Session- und Lock-Konzept
14. 13. Password-Safe-Interop, Import und Export
15. 14. Suche, Filter, Tags und Organisation
16. 15. Passwortgenerator, Vorlagen und Standardmetadaten
17. 16. Entwicklung, Tests und Dokumentation
18. 17. Abnahmekriterien für V1.0
19. 18. Risiken, offene Konzeptthemen und Nicht-Ziele
20. Anhang A - Vollständige Anforderungsmatrix
21. Anhang B - Vorgeschlagene Umsetzungspakete bis V1.0

Management Summary

Dieses Pflichtenheft konkretisiert das überarbeitete Lastenheft des SASD Desktop Secret Managers in eine arbeitsfähige Umsetzungs- und Ausführungsspezifikation. Es beschreibt, wie die fachlichen Anforderungen technisch, organisatorisch und in der Benutzeroberfläche umzusetzen sind. Neu ausdrücklich integriert ist die strukturierte Verwaltung von HTTPS/TLS-Zertifikaten als eigener Secret-Kontext.

Das Zielsystem bleibt ein lokaler, offline-first nutzbarer Windows-Desktop-Secret-Manager auf Basis von C#.NET und WinForms. Es verwaltet mehrere voneinander unabhängige verschlüsselte Tresore, bildet klassische Logins und technische Betriebszugänge ab, unterstützt Gruppen, Tags, Zusatzfelder, sichere Anzeige, kontrolliertes Kopieren, Auto-Lock, Backups und realistische Password-Safe-Interop.

Das interne Datenmodell bleibt führend. Password Safe wird nicht zum einschränkenden Maß der Anwendung gemacht, sondern als Import- und Interop-Quelle behandelt. Ebenso bleibt die Anwendung in V1 bewusst ohne Cloud-Zwang, Team-Sharing, Browser-Autofill, mobile Clients und automatische Zertifikats- oder PKI-Automation.

Leitentscheidung. V1 soll eine runde lokale Erstversion werden: klein genug, um beherrschbar und sicher zu bleiben, aber vollständig genug, um im Alltag für SASD-nahe technische Zugangsdaten einschließlich Zertifikatsinformationen sinnvoll nutzbar zu sein.

1. Dokumentzweck, Quellenbasis und Verbindlichkeit

Dieses Dokument ist das technische Ausführungsdokument zum konsolidierten Lastenheft. Es übersetzt die fachlichen Anforderungen in konkrete Pflichten für Datenmodell, Architektur, Bedienung, Sicherheit, Dateiformat, Interoperabilität, Test und Release-Abnahme.

Die Quellenbasis umfasst das fortgeschriebene Lastenheft und Pflichtenheft, das Architektur-Dokument, Featuremap und Roadmap, die Feature-Collation zu Passwortmanagern, den aktuellen Repository-Stand sowie die projektbezogenen Chats. Gegenüber älteren Fassungen wurden insbesondere die Zertifikatsverwaltung, die aktuelle Repository-Realität und die klarere V1/V1.x/V2-Zuordnung eingearbeitet.

V1.0-Pflichten sind verbindlich für die erste runde lokale Version. V1.x-Pflichten sind verbindliche Folgeausbauten nach Stabilisierung des V1-Kerns. V2 und V3/später beschreiben geplante oder mögliche Erweiterungen, die nicht ohne eigene Entscheidung in die V1-Lieferpflicht fallen.

Wichtige Lesart. Das Pflichtenheft beschreibt nicht nur neue Funktionen, sondern auch Grenzen. Gerade bei einem Secret Manager ist es fachlich wichtig, vertagte und abgelehnte Ideen sichtbar zu halten, damit später keine stillen Annahmen entstehen.

2. Zielsystem, Einsatzkontext und bewusste Abgrenzung

Das Zielsystem ist eine lokale Einzelbenutzer-Anwendung für Windows 10 und Windows 11. Die Anwendung soll ohne Web-Backend, Online-Konto oder Cloud-Synchronisation nutzbar sein. Lokale Einstellungen wie Fensterposition, zuletzt verwendete Tresorpfade oder UI-Vorlieben dürfen gespeichert werden; geheime Inhalte und Master-Passwörter dürfen außerhalb des verschlüsselten Tresors nicht gespeichert werden.

Der Hauptnutzen liegt in der Verwaltung klassischer und technischer Zugangsdaten: Web-Logins, Hosting-Backends, Datenbanken, Mailkonten, FTP/SFTP-Zugänge, Server- und Infrastrukturzugänge, API-Secrets, Lizenzinformationen, sichere Notizen und HTTPS/TLS-Zertifikatsinformationen.

Nicht Bestandteil von V1 sind Cloud-Sync, Team-Vaults, Browser-Autofill, mobile Clients, Web-Frontend, Multi-User-Rechtemodell, automatische ACME-Erneuerung, vollständige PKI-Verwaltung, automatische Server-Deployments und eine heimliche Recovery-Backdoor.

2.1 Ziel- und Nicht-Ziel-Abgrenzung

Bereich	V1-Ziel	Nicht V1-Ziel
Betriebsmodell	Lokale Windows-Desktop-Anwendung, offline-first	Cloud-Dienst, Web-App, mobiler Client
Nutzung	Single-User, ein aktiver schreibbarer Tresor pro Fenster	Team-Sharing, Rollen-/Rechteverwaltung
Datenmodell	Mehrere Secret-Typen, Gruppen, Tags, Zusatzfelder, Zertifikatseinträge	Vollständige Enterprise-PAM-/PKI-Suite

Bereich	V1-Ziel	Nicht V1-Ziel
Interop	Kontrollierter Password-Safe-Import mit Bericht	Roundtrip-stabile vollständige .psafe3-Bearbeitung
Zertifikate	Manuelle strukturierte Erfassung und sichere Ablage relevanter Informationen	ACME-Automation, automatische Verlängerung, CT-Monitoring

3. Release- und Lieferstrategie

Die Release-Strategie richtet sich nach dem aktualisierten Lastenheft. Der aktuelle Prototyp wird als V0.x-Entwicklungsstand verstanden. V1.0 ist erst dann erreicht, wenn die offenen Alltagssicherheits- und Komfortfunktionen integriert, getestet und dokumentiert sind.

3.1 Versionen und verbindliche Einordnung

Version	Zielcharakter	Inhalt	Einordnung
V0.x	Entwicklungsstand	Vorhandener WinForms-Prototyp mit .svault, Gruppen, Tags, Suche, CRUD, Drag-and-Drop und Tests.	Nicht produktiv freigeben. Grundlage für V1.
V1.0	Runde lokale Erstversion	Mehrere Tresore, Secret-Typen inklusive HTTPS/TLS-Zertifikat, sichere Anzeige, Clipboard-Autoclear, Auto-Lock, Passwortgenerator, Backups, .psafe3-Import.	Verbindlicher Abnahmekern.
V1.x	Härtung und Produktpolitur	Master-Passwort-Änderung, Restore-Sicherheit, bessere Konfliktbehandlung, Vorlagen, Generatorprofile, Tag-Verwaltung, Zertifikatsablauf-Warnungen, Produkticon.	Verbindlicher Folgeausbau.
V2	Funktionsausbau	Mehrsprachigkeit, Themes, Cross-Vault-Funktionen, Historie, TOTP, verschlüsselte Anhänge, Zertifikatsdateien, optionale Online-Prüfungen.	Geplante Ausbaustufe.
V3/später	Heikle/strategische Erweiterungen	Browser-Import, Passkeys, ACME-/PKI-Automation, Team-/Cloud-/Mobile-Strategien.	Nur nach separater Bewertung.

Konsequenz für die Entwicklung: Die nächsten Umsetzungspakete sollen nicht wahllos neue Features hinzufügen, sondern die V1-Lücke schließen: Clipboard-Schutz, Dirty-/Datenverlustschutz, Lock/Auto-Lock, Passwortgenerator, Zertifikatseintrag, .psafe3-Import und Release-Härtung.

4. Technologischer Lösungsrahmen und Projektstruktur

Die Anwendung wird in C# auf Basis von .NET 8 und WinForms umgesetzt. Diese Wahl bleibt für die erste lokale Windows-Version pragmatisch und passend. Entscheidend ist jedoch, dass WinForms nicht zur Sammelstelle für Kryptografie, Persistenz und Fachlogik wird.

Die bestehende Schichtenstruktur ist beizubehalten und gezielt auszubauen. Neue Funktionen müssen bevorzugt als Domain-, Application-, Security-, Storage- oder Interop-Bausteine entstehen und erst danach sauber in die UI eingebunden werden.

4.1 Verbindliche Projektstruktur

Pfad	Verantwortung
src/Sasd.SecretManager.Domain	Fachliches Modell: Vault, Group, SecretEntry, EntryType, CustomField, Zertifikatsfeldtypen und fachliche Regeln ohne UI-Abhängigkeit.

Pfad	Verantwortung
src/Sasd.SecretManager.Application	Use Cases, Query-/Mutation-/Organisation-Services, ViewModels, Zertifikats-ViewModel, Import-/Export-Abläufe.
src/Sasd.SecretManager.Security	KDF, Verschlüsselung, Passwortbewertung, Passwortgenerator, Clipboard-Schutz, Auto-Lock-Policies, Redaction-Regeln.
src/Sasd.SecretManager.Storage	Internes .svault-Format, atomisches Speichern, Backups, Restore-Hilfen, Migrationen, Dateisperren.
src/Sasd.SecretManager.Interop.PasswordSafe	Reader, Mapping, Importbericht; spätere Writer- und Kompatibilitätsfunktionen.
src/Sasd.SecretManager.WinForms	Hauptfenster, Dialoge, Detailansichten, Kontextmenüs, sichere UI-Aktionen.
tests/*	Unit-, Integrations-, Negativ- und Interop-Tests je Schicht.
docs/*	Lastenheft, Pflichtenheft, Architektur, ADRs, Roadmap, Benutzer-/Entwicklerdokumentation.
Codequalität. Öffentliche Klassen und zentrale Methoden erhalten XML-Kommentare. Komplexe Logik wird zusätzlich mit erklärenden Kommentaren versehen. Kommentare sollen Verständnis schaffen, nicht schlechte Struktur kaschieren.	

5. Zielarchitektur und Schichtenverantwortung

Die Zielarchitektur trennt fachliche Daten, Anwendungsregeln, Sicherheitsfunktionen, Persistenz, Interoperabilität und UI. Dadurch kann der Secret Manager wachsen, ohne dass sicherheitskritische Logik in Form-Klassen verteilt wird.

5.1 Schichten und verbindliche Verantwortlichkeiten

Schicht	Pflichten
Domain	Reine fachliche Objekte und Enums. Keine UI, keine Dateipfade, keine Kryptografie-Primitive. Neue Typen wie HTTPS/TLS-Zertifikat werden hier fachlich abgebildet.
Application	Bearbeitungsmodelle, Such- und Filterlogik, Organisationslogik, Entry-Templates, Zertifikatsdarstellung, Import-Assistent-Logik.
Security	Kryptografische Hilfsdienste, Passwortgenerator, Passwortqualität, Clipboard-Autoclear, Lock/Auto-Lock, sichere Redaction von Log-Ausgaben.
Storage	Serialisierung, .svault-Container, KDF-Parameter, atomisches Schreiben, Backups, Dateisperren, Fehlerbehandlung, spätere Formatmigrationen.
Interop.PasswordSafe	Additive Fremdformatverarbeitung. Mapping in das interne Modell. Importwarnungen statt stiller Datenverluste.
WinForms/UI	Anzeige, Dialogführung, Eingabevalidierung, Benutzerfeedback. Keine direkte Kryptografie und keine eigenständige Speicherlogik.
Tests	Nachweis, dass Fachlogik, Kryptografie, Persistenz, Import, Zertifikatsfelder und Sicherheits-UX verlässlich arbeiten.

Für weitere Entwicklung gilt: Neue Features werden zunächst fachlich und sicherheitlich eingeordnet, dann in der passenden Schicht implementiert und erst zum Schluss in die Oberfläche verdrahtet.

6. Fachliches Datenmodell und Persistenzmodell

Das interne Datenmodell ist führend. Es beschreibt die fachliche Realität der Anwendung und darf nicht auf die Grenzen eines Fremdformats reduziert werden. Der zentrale Eintrag bleibt ein SecretEntry mit Typ, Kernfeldern, Tags, Zusatzfeldern, Notizen, Zeitstempeln und Gruppenzuordnung.

6.1 Haupteinheiten

Einheit	Verbindliche Umsetzung
Vault	Eigene ID, Anzeigename, Modellversion, Gruppen, Einträge, bekannte Tags, Format-/KDF-Metadaten, optional nicht-geheime Tresor-Metadaten.
Group	Hierarchischer Knoten mit stabiler ID, Name, Parent-Bezug und berechenbarem Pfad. Schutz gegen Zyklen und ungültige Verschiebungen.
SecretEntry	Eintrag mit ID, EntryType, Titel, Principal/Username, Secret-Wert, Notizen, Gruppe, Tags, CustomFields, CreatedUtc, ModifiedUtc und optionalem Status.
Tag	Normalisiertes Schlagwort zur Querverknüpfung. Tags sind nicht Ersatz für Gruppen, sondern ergänzende Suche und Filterung.
CustomField	Name, Wert, Feldtyp, Secret-Markierung, Sortierreihenfolge. Secret-Felder werden maskiert, kontrolliert kopiert und nicht geloggt.

Zeitstempel sind verpflichtend. Passwort-Historie, Eintragsreferenzen und Anhänge sind spätere Ausbauten und dürfen das V1-Datenmodell nicht verkomplizieren, müssen aber durch Versionierung und CustomFields vorbereitbar bleiben.

7. Secret-Typen und Feldspezifikationen

V1 unterstützt mindestens die folgenden EntryTypes: Login, Database, Mail, Hosting, FTP/SFTP, Server, API, License, SecureNote, Custom und HttpsTlsCertificate. Die Typen steuern Anzeige, Feldvorschläge, Templates und spätere Validierungen. Sie dürfen die Nutzung flexibler Zusatzfelder nicht verhindern.

7.1 Eintragsstypen und typische Felder

Typ	Pflicht-/Standardfelder	Besonderheiten
Login	Titel, URL, Benutzername, Passwort, Notizen, Tags	Klassischer Web-/Portalzugang.
Database	Host, Port, Datenbank, Schema, Benutzername, Passwort, Umgebung	SSL/TLS-Hinweise und Rollenbezug als Zusatzfelder.
Mail	E-Mail-Adresse, IMAP-/SMTP-Host, Ports, TLS, Benutzername, Passwort	Serverdaten nicht nur in Notizen verstecken.
Hosting	Provider, Backend-URL, Kundennummer, Benutzername, Passwort, Vertrags-/Paketbezug	Geeignet für IONOS-/Provider-Kontexte.
FTP/SFTP	Host, Port, Protokoll, Benutzername, Passwort/Key-Hinweis, Zielpfad	SFTP-Schlüsselhinweise als Secret oder Notiz abbilden.
Server	Hostname/IP, Protokoll, Port, Benutzer, Authentifizierungsart, Umgebung	Passwort, Key-Passphrase oder Hinweis auf separaten Schlüssel.
API	Endpoint, Client-ID, Secret, Token, Scope, Umgebung, Ablaufdatum	Secret- und Token-Felder konsequent maskieren.
License	Produkt, Hersteller, Lizenzschlüssel, Ablaufdatum, Vertragsbezug	Lizenzschlüssel kann Secret sein.
SecureNote	Titel, Notiz, optionale Secret-Zusatzfelder	Für Inhalte ohne passendes Schema.
HTTPS/TLS-Zertifikat	Domain/CN, SANs, Aussteller, Seriennummer, Fingerprint, gültig von/bis, Deployment-Ziel, private Key-/PFX-Informationen	Eigener Pflichtabschnitt in Kapitel 8.

7.2 CustomFieldKind Mindestumfang

Feldtyp	Verhalten
Text	Normaler Such- und Anzeigehalt.
Secret	Standardmäßig maskiert, Copy mit Clipboard-Autoclear, keine Klartext-Logs.
URL	Als Adresse erkennbar, später optional Öffnen-Aktion.
Hostname	Suchbar, gut für Server-, Datenbank- und Zertifikatseinträge.
Port	Numerische Portangabe mit Plausibilitätsprüfung.
Email	E-Mail-Adresse mit einfacher Plausibilitätsprüfung.
Date	Datum für Ablauf, Erneuerung, Prüfung, Gültigkeit.
Number	Zahlwert, z. B. Kundennummer oder Port, wenn Port-Typ nicht passt.
Boolean	Ja/Nein-Wert, z. B. Wildcard-Zertifikat oder Produktionssystem.
MultilineText	Mehrzeiliger nicht-geheimer Text, z. B. strukturierte Hinweise.
CertificateText	Mehrzeiliger Zertifikatstext in PEM/CRT-Form; in V1 nur kontrolliert als Textfeld, Dateianhänge später.

8. HTTPS/TLS-Zertifikatsverwaltung

Die Verwaltung von HTTPS/TLS-Zertifikaten wird als eigener fachlicher Secret-Kontext umgesetzt. Ziel ist nicht, in V1 eine vollständige PKI- oder ACME-Plattform zu bauen, sondern Zertifikate und zugehörige Betriebsinformationen so strukturiert zu erfassen, dass Betrieb, Erneuerung, Deployment und Wiederauffindbarkeit unterstützt werden.

8.1 Fachliches Modell des Zertifikatseintrags

Ein Zertifikatseintrag ist ein SecretEntry mit EntryType HttpsTlsCertificate. Er kann ein Zertifikat, einen Zertifikatsbezug oder eine Zertifikatsinstallation beschreiben. V1 legt den Fokus auf manuelle strukturierte Erfassung, sichere Ablage sensibler Felder und gute Suche. Automatische Zertifikatsanalyse und Dateianhänge werden nicht erzwungen.

8.1 Pflicht- und Standardfelder für HTTPS/TLS-Zertifikate

Feld	Typ	Pflicht V1	Beschreibung
Titel	Text	Ja	Sprechender Name, z. B. www.sasd.example Produktionszertifikat.
PrimaryDomain / CommonName	Hostname/Text	Ja	Hauptdomain oder Common Name.
SubjectAlternativeNames	MultilineText	Soll	Liste weiterer DNS-Namen; eine Domain pro Zeile oder kommasepariert.
IsWildcard	Boolean	Soll	Kennzeichnung, ob es sich um ein Wildcard-Zertifikat handelt.
Issuer	Text	Soll	Aussteller/CA, z. B. Let's Encrypt, Sectigo, interne CA.
SerialNumber	Text	Soll	Seriennummer zur eindeutigen Identifikation.
FingerprintSha256	Text	Soll	Fingerabdruck/Thumbprint zur Kontrolle.
ValidFrom	Date	Soll	Beginn der Gültigkeit.

Feld	Typ	Pflicht V1	Beschreibung
ValidTo	Date	Ja	Ablaufdatum; Grundlage für spätere Warnungen.
CertificateFormat	Text	Soll	PEM, CRT, CER, PFX, P12 oder anderer Hinweis.
DeploymentTarget	Text	Soll	Server, Hosting, Reverse Proxy, Webservice, Load Balancer oder Anwendung.
Environment	Text	Soll	Produktion, Test, Entwicklung, Staging.
RenewalMethod	Text	Soll	Manuell, Provider-Portal, ACME extern, Kunde liefert, interne CA.
Responsible	Text	Kann	Verantwortliche Person oder Rolle.
PrivateKeyLocation	Text	Kann	Hinweis, wo der private Schlüssel liegt, sofern nicht im Tresor gespeichert.
PrivateKeyPassphrase	Secret	Kann	Geheime Passphrase, falls erforderlich.
PfxPassword	Secret	Kann	Passwort für PFX/P12-Datei.
CertificatePem	CertificateText	Kann	Zertifikatstext, falls bewusst im Tresor abgelegt.
PrivateKeyPem	Secret/CertificateText	Kann	Privater Schlüssel nur nach bewusster Entscheidung; UI muss warnen.

8.2 UI-Verhalten für Zertifikatseinträge

Der Editierdialog muss für Zertifikatseinträge eine eigene Feldgruppe anbieten. Fachlich zusammengehörige Felder werden in Blöcken dargestellt: Identität, Gültigkeit, Aussteller/Fingerprint, Deployment/Erneuerung und sensible Schlüssel-/PFX-Daten.

- Geheime Zertifikatsfelder wie PFX-Passwort, Key-Passphrase oder privater Schlüssel sind standardmäßig maskiert.
- Beim Befüllen eines privaten Schlüssel-Felds zeigt die UI einen Hinweis, dass ein privater Schlüssel besonders schützenswert ist und nicht leichtfertig dupliziert werden sollte.
- Ablaufdatum und Domain müssen in der Detailansicht prominent erscheinen, damit ablaufende Zertifikate nicht in Notizen verborgen bleiben.
- SANs werden mehrzeilig angezeigt und in die Suche einbezogen.
- Zertifikatseinträge sollen nach Ablaufdatum sortier- und später filterbar sein.

8.3 Versionszuordnung der Zertifikatsfunktionen

8.2 Zertifikatsfunktionen nach Version

Funktion	Version	Pflichtgrad	Bemerkung
EntryType HttpsTlsCertificate	V1.0	Muss	Eigenständiger Typ mit angepasster Detail- und Editierlogik.
Manuelle Zertifikatsmetadaten	V1.0	Muss	CN, SANs, Issuer, Serial, Fingerprint, ValidTo, Deployment.
Sensible Key-/PFX-Felder	V1.0	Muss	Maskiert, Copy geschützt, keine Logs.
Suche über Domain, SANs, Issuer, Deployment	V1.0	Muss	Zertifikate müssen zuverlässig auffindbar sein.

Funktion	Version	Pflichtgrad	Bemerkung
Ablaufdatum in Detailansicht	V1.0	Muss	Sichtbar ohne Secret-Reveal.
Zertifikatsablauf-Warnungen	V1.x	Soll	Warnlisten, Schwellen z. B. 30/14/7 Tage.
Zertifikats-Template	V1.x	Soll	Schneller Dialog für typische Webserver-Zertifikate.
Import/Parsing aus PEM/CRT/PFX	V2	Kann/Soll	Nur lokal, ohne Netzpflicht.
Verschlüsselte Zertifikatsdatei-Anhänge	V2	Kann/Soll	Für CER/CRT/PFX/Chain-Dateien, wenn Attachment-Modell vorhanden ist.
ACME-/PKI-Automation	V3/später	Optional	Separates Konzept nötig; nicht in V1 versprechen.

8.4 Grenzen und Sicherheitsregeln

Die Zertifikatsverwaltung darf nicht den Eindruck erwecken, dass der Secret Manager automatisch Server absichert oder Zertifikate erneuert. Die Anwendung speichert und strukturiert Informationen. Automatisierte Erneuerung, Deployment, OCSP-/CT-Überwachung und PKI-Workflows sind spätere, getrennt zu bewertende Themen.

Sicherheitsregel Zertifikate. Private Schlüssel, PFX/P12-Passwörter und Key-Passphrases sind Secrets. Sie dürfen nicht in Klartextlogs, unverschlüsselten Exporten, temporären Dateien oder ungeschützten Vorschauen erscheinen.

9. Bedien- und UI-Konzept

Die Oberfläche folgt dem ruhigen Drei-Zonen-Modell: links Tresor-/Gruppenbaum, mittig Suche und Eintragsliste, rechts strukturierte Detailansicht. Menüleiste, Kontextmenüs und Dialoge sind wichtiger als eine überladene Button-Fläche.

9.1 Hauptoberfläche

UI-Bereich	Pflichtverhalten
Tresor-/Gruppenbaum	Sichtbarer Root-/Tresorknoten, Hauptgruppen, Untergruppen, Kontextmenüs, Drag-and-Drop-Ziele, Schutz gegen ungültige Gruppenverschiebungen.
Suche und Filter	Case-insensitive Standardsuche über Titel, Benutzer, Gruppen, Tags, Notizen, Typen und nicht-geheime Zusatzfelder; Typ- und Tagfilter für V1/V1.x.
Eintragsliste	Übersicht der Treffer ohne Klartext-Secrets; Spalten für Titel, Typ, Benutzer/Principal, Gruppe, Tags, ModifiedUtc; Zertifikate optional mit ValidTo.
Detailansicht	Strukturierte Anzeige der Kernfelder, Tags und Zusatzfelder; Secret-Reveal und Copy nur explizit; Zertifikatsfelder gruppiert anzeigen.
Editierdialog	Anlegen/Bearbeiten von Einträgen, Zusatzfeldern, Tags und typabhängigen Feldern; Validierungen ohne unnötige Blockade.
Statusleiste	Rückmeldungen zu Auswahl, Speichern, Dirty-State, Copy-Aktionen, Drag-and-Drop, Auto-Lock und Importberichten.

Unsichere oder folgenreiche Aktionen wie Löschen, Verschieben ganzer Gruppen, Überschreiben von Dateien, Import mit Verlusthinweisen oder unverschlüsselter Export müssen explizite Bestätigungen erhalten.

10. Sicherheitskonzept und Schutzgrenzen

Das Produkt schützt primär gegen Diebstahl oder Verlust der Tresordatei, neugierige Mitleser am Arbeitsplatz, versehentliche Offenlegung durch UI oder Clipboard, Datenverlust bei Speichervorgängen und unsaubere Import-/Export-

Prozesse. Nicht versprochen wird Schutz gegen ein vollständig kompromittiertes Betriebssystem, Malware, Keylogger, RAM-Auslese oder manipulierte Installationsumgebung.

10.1 Sicherheitsregeln

Bereich	Pflicht
Master-Passwort	Nie im Klartext speichern, nie loggen, nur für Entsperren/Speichern/Passwortwechsel verwenden.
KDF/Verschlüsselung	KDF-Parameter pro Tresor speichern. Aktueller .svault-Ansatz mit PBKDF2-SHA256 und AES-256-GCM bleibt zulässig, wenn Parameter versioniert sind; Argon2id kann später über Formatmigration ergänzt werden.
Secrets im UI	Standardmäßig maskiert. Reveal nur bewusst, temporär und lokal.
Clipboard	Sensible Copy-Aktionen über zentralen ClipboardProtectionService, Auto-Clear nach konfigurierbarer Zeit, Feedback in Statusleiste.
Auto-Lock	Sperre nach Inaktivität; sichtbare Secret-Felder leeren/maskieren; Entsperren nur mit Master-Passwort des aktiven Tresors.
Logging	Keine Passwörter, Tokens, privaten Schlüssel, PFX-Passwörter, vollständigen Connection Strings oder geheimen Zusatzfelder loggen.
Exports	Unverschlüsselte Exporte nur nach Warnung und ausdrücklicher Entscheidung; keine automatische Ablage im Download- oder Cloud-Sync-Ordner.
Recovery	Keine heimliche Backdoor. Spätere Recovery nur als vorher eingerichteter, dokumentierter Mechanismus.

Sicherheitsfunktionen müssen ehrlich dokumentiert werden. Eine Integritätsprüfung eigener Programmdateien kann einfache Manipulationen erkennen, ersetzt aber kein vertrauenswürdiges Betriebssystem und keine saubere Installationskette.

11. Vault-Dateiformat, Backups und Restore

Das Primärformat ist .svault. Der Container enthält eine klare Formatkennung, Version, KDF-Parameter, Salt, Nonce, Authentifizierungstag und verschlüsselte Nutzlast. Die Nutzlast enthält das versionierte interne Datenmodell.

11.1 Dateiverwaltungspflichten

Thema	Pflicht
Formatkennung	Magic-Header und FormatVersion müssen ungültige oder fremde Dateien erkennen.
KDF-Parameter	Iterationszahl/Profil, Salt und spätere KDF-Informationen im Container speichern.
Atomisches Speichern	Zuerst temporär schreiben, flushen, validieren und dann kontrolliert ersetzen. Keine halb geschriebenen Tresore als Erfolg melden.
Backups	Beim Überschreiben eine verschlüsselte Backup-Datei erzeugen; V1.x mit rotierenden Backups und zusätzlichem LocalAppData-Ort erweitern.
Dateisperren	Parallele schreibende Bearbeitung derselben Datei verhindern oder konservativ read-only behandeln.
Fehlerbehandlung	Falsches Passwort, beschädigte Datei, fehlende Rechte, unbekannte Formatversion und abgebrochene Schreibvorgänge klar unterscheiden.
Restore	Restore-Vorgänge erst V1.x komfortabel, aber Backups müssen schon in V1 so entstehen, dass eine manuelle Wiederherstellung möglich ist.

12. Mehrtresor-, Session- und Lock-Konzept

Mehrere unabhängige Tresore sind Kernanforderung. Jeder Tresor besitzt eigene Datei, eigenes Master-Passwort, eigene KDF-Parameter und eigene Backup-Kette. In V1 ist pro Programmfenster genau ein aktiver schreibbarer Tresor vorgesehen.

12.1 Session-Verhalten

Situation	Pflichtverhalten
Programmstart	Optional Demo-/Willkommenszustand; keine automatische Entsperrung echter Tresore ohne Master-Passwort.
Neuer Tresor	Name und Master-Passwort abfragen, Passwortstärke bewerten, leere Grundstruktur erzeugen.
Tresor öffnen	Datei wählen, Master-Passwort abfragen, bei Erfolg UI neu aufbauen.
Tresor wechseln	Dirty-State prüfen; Speichern/Verwerfen/Abbrechen anbieten.
Auto-Lock	Nach Inaktivität sperren; Details und Listen so zurücksetzen, dass keine Secrets sichtbar bleiben.
Entsperren	Master-Passwort des aktiven Tresors erneut verlangen; kein anderes Tresorpasswort akzeptieren.
Beenden	Dirty-State prüfen, Speichern anbieten, sensible UI-Zustände zurücksetzen.

13. Password-Safe-Interop, Import und Export

Die Interoperabilität mit Password Safe wird additiv umgesetzt. Das interne Modell bleibt führend. Ein .psafe3-Import darf keine stillen Datenverluste verursachen; nicht abbildbare oder unsicher interpretierte Informationen müssen im Importbericht erscheinen.

13.1 Interop-Bausteine

Baustein	Version	Pflicht
Reader für .psafe3	V1.0	Datei lesen, Passwort prüfen, Einträge extrahieren, Fehler klar melden.
Mapping ins interne Modell	V1.0	Titel, Benutzername, Passwort, URL, Gruppe, Notizen direkt übernehmen; Sonderfelder als CustomFields oder Import-Metadaten.
Import-Assistent	V1.0	Quelle wählen, Ziel prüfen, Ergebnis zusammenfassen, Importbericht anzeigen/speichern.
Importbericht	V1.0	Anzahl Einträge, Warnungen, nicht abbildbare Felder, Konflikte, Duplikatverdacht.
Export nach .psafe3	V1.x/V2	Nur klar abbildbare Inhalte; Verlusthinweise zwingend.
CSV-Export	V2	Nur nach Warnung; unverschlüsselt und riskant kennzeichnen.
Browser-Import	V3/später	Datenschutz- und Browserabhängigkeit separat bewerten.

Importierte Inhalte sollten nach Möglichkeit mit einem Tag wie import:pwsafe oder einer Importquelle markiert werden, damit der Nutzer später Nacharbeit und Validierung gezielt durchführen kann.

14. Suche, Filter, Tags und Organisation

Suche und Wiederauffindbarkeit sind Kernfunktionen. Die Standardsuche ist case-insensitive. Eine spätere Fallunterscheidung ist optional, darf aber die einfache Standardsuche nicht verschlechtern.

14.1 Such- und Filterumfang

Bereich	V1-Pflicht
Titel und Benutzer/Principal	Vollständig durchsuchen.
Gruppenpfad	Einträge über sichtbaren Pfad und Untergruppen auffindbar machen.
Tags	Tags normalisieren, deduplizieren, anklickbar und filterbar machen.
Notizen	Durchsuchbar, jedoch keine Secret-Notizen in separaten unverschlüsselten Indizes.
Nicht-geheime Zusatzfelder	Durchsuchbar, z. B. Host, Port, Domain, SAN, Datenbankname, Deployment-Ziel.
Geheime Zusatzfelder	Nicht in Klartextlisten oder Logs. Suche nur, wenn sie ohne zusätzlichen Klartextindex innerhalb des entsperren Tresors erfolgt.
Zertifikate	Domain, SANs, Issuer, Fingerprint, DeploymentTarget und ValidTo für Suche/Filter berücksichtigen.

Drag-and-Drop für Einträge und Gruppen bleibt Bestandteil von V1. Gruppenverschiebungen müssen Zyklen verhindern und bei weitreichenden Auswirkungen bestätigen lassen.

15. Passwortgenerator, Vorlagen und Standardmetadaten

Gruppenweite Default-Passwörter werden ausdrücklich nicht umgesetzt. Stattdessen werden Passwortgenerator, Generatorprofile, Eintragsvorlagen und gruppenbezogene Standardmetadaten genutzt. Dadurch wird Wiederverwendung von Passwörtern vermieden, während die Eingabe technischer Standardkontexte erleichtert wird.

15.1 Generator- und Vorlagenpflichten

Funktion	Version	Umsetzung
Passwortgenerator	V1.0	Länge, Zeichensatzoptionen, Ausschluss schwer lesbarer Zeichen, Kopieren/Übernehmen in Eintrag, keine Protokollierung generierter Werte.
Generatorprofile	V1.x	Profile wie Standard, sehr stark, kompatibel, PIN/Token-ähnlich; keine unsicheren Defaults.
Eintragsvorlagen	V1.x	Vorlagen für Login, Mail, Database, FTP/SFTP, API und Zertifikat.
Gruppenbezogene Standardmetadaten	V1.x/V2	Vorschläge für Provider, Umgebung, Kunde, Projekt, nicht aber Passwortwerte.

16. Entwicklung, Tests und Dokumentation

Die Entwicklung folgt einem inkrementellen, testorientierten Vorgehen. Jede neue fachliche Funktion erhält nach Möglichkeit Tests in der passenden Schicht. UI-nahe Sicherheitsfunktionen werden zusätzlich manuell mit reproduzierbaren Testfällen geprüft.

16.1 Testpflichten

Testebene	Pflichtumfang
Domain-Tests	EntryTypes, CustomFields, Gruppenstruktur, Tag-Normalisierung, Zertifikatsfeldmodell.

Testebene	Pflichtumfang
Application-Tests	Suche, Filter, Entry-Mutation, Organisation, Drag-and-Drop-Regeln, Zertifikats-ViewModel, Import-Mapping.
Security-Tests	Passwortbewertung, Passwortgenerator, KDF-Hilfen, ClipboardProtectionService, Lock-Policy.
Storage-Tests	Speichern/Laden, falsches Passwort, beschädigte Datei, Backup, Formatversion, Dateipfadvalidierung.
Interop-Tests	Password-Safe-Reader, Mapping, Importberichte, Fehlerszenarien.
Manuelle QA	V1-Abnahmeabläufe, UI-Dialoge, Copy/Reveal, Auto-Lock, Zertifikatseintrag, Import-Warnungen.

16.2 Dokumentationspflichten

Dokument	Pflicht
README	Aktueller Status, Warnung vor Produktivnutzung, Build/Test-Anleitung, Funktionsumfang.
Lastenheft	Fachliches Zielbild und Versionslogik aktuell halten.
Pflichtenheft	Umsetzungs- und Abnahmepflichten aktuell halten.
Architekturdokument	Schichten, zentrale Klassen, Datenfluss, Sicherheits- und Speicherentscheidungen.
ADRs	Wichtige Entscheidungen: KDF, .svault, Zertifikatsmodell, Interop, Recovery, Export.
Benutzerkurzdoku	V1-Bedienung: Tresor anlegen, Einträge, Zertifikate, Suche, Backup, Import, Sicherheitshinweise.

17. Abnahmekriterien für V1.0

V1.0 ist abnahmefähig, wenn die Anwendung die definierten Alltagsszenarien reproduzierbar, sicher und ohne kritische Datenverluste erfüllt. Die Abnahme erfolgt nicht nur über vorhandene Menüpunkte, sondern über erfolgreiche End-to-End-Abläufe.

17.1 V1-Abnahmekriterien

ID	Kriterium
AK-01	Neuer .svault-Tresor kann angelegt, mit Master-Passwort geschützt, gespeichert, geschlossen und wieder geöffnet werden.
AK-02	Mehrere unabhängige Tresore bleiben getrennt; kein Vermischen von Gruppen, Einträgen oder Master-Passwörtern.
AK-03	Einträge der Typen Login, Database, Mail, Hosting, FTP/SFTP, Server, API, License, SecureNote, Custom und HTTPS/TLS-Zertifikat können angelegt und bearbeitet werden.
AK-04	Zertifikatseinträge können Domain/CN, SANS, Issuer, Fingerprint, ValidTo, Deployment-Ziel und sensible Key-/PFX-Felder strukturiert speichern und anzeigen.
AK-05	Secrets bleiben standardmäßig verborgen; Reveal und Copy funktionieren kontrolliert.
AK-06	Clipboard-Autoclear löscht sensible kopierte Werte nach definierter Zeit und gibt verständliches Feedback.
AK-07	Auto-Lock sperrt den Tresor nach Inaktivität und lässt keine Secrets sichtbar zurück.

ID	Kriterium
AK-08	Passwortgenerator erzeugt starke Passwörter und übernimmt sie ohne Logging in Einträge.
AK-09	Suche findet Einträge über Titel, Gruppen, Tags, Typen, Notizen und nicht-geheime Zusatzfelder, einschließlich Zertifikatsdomains und SANs.
AK-10	Gruppen und Einträge lassen sich per Kontextmenü und Drag-and-Drop organisieren; ungültige Aktionen werden verhindert oder bestätigt.
AK-11	Speichern erfolgt atomisch; verschlüsselte Backups werden erzeugt; beschädigte oder falsche Dateien werden verständlich gemeldet.
AK-12	Password-Safe-Import aus .psafe3 erzeugt nachvollziehbare Einträge und einen Importbericht mit Warnungen.
AK-13	Keine Secrets, privaten Schlüssel, Tokens oder Master-Passwörter erscheinen in Logs, Fehlermeldungen oder unverschlüsselten temporären Dateien.
AK-14	Build und Tests laufen grün; manuelle V1-Testliste ist dokumentiert.

18. Risiken, offene Konzeptthemen und Nicht-Ziele

18.1 Risiken und Gegenmaßnahmen

Risiko	Gegenmaßnahme
Zu breiter V1-Umfang	V1 auf lokale Kernnutzung konzentrieren; V2/V3 sichtbar dokumentieren, aber nicht vorziehen.
Zertifikatsverwaltung wird zur PKI-Plattform	V1 nur strukturierte Verwaltung; ACME/PKI/Deployment separat bewerten.
Secret-Leaks über Logs oder Clipboard	Zentrale Redaction- und Clipboard-Services; Tests und manuelle QA.
Datenverlust bei Speichern	Atomisches Speichern, Backups, klare Fehlerbehandlung.
Interop-Datenverlust	Importbericht, Mapping-Regeln, keine stillen Verluste.
MainForm wächst zu stark	Neue Logik in Services/ViewModels auslagern, UI nur orchestrieren lassen.
Falsches Sicherheitsversprechen	Schutzgrenzen explizit dokumentieren.

Bewusste Nicht-Ziele bleiben: vollständiger 1:1-Klon von Password Safe, gruppenweite Default-Passwörter, versteckte Recovery-Backdoor, Cloud-Sync und Team-Sharing in V1, Browser-Autofill in V1, automatische ACME-/PKI-Verwaltung in V1, virtuelle Tastatur als Kernfunktion und unkommentierte sicherheitskritische Magie.

Anhang A - Vollständige Anforderungsmatrix

Die folgende Matrix dient als Entscheidungs- und Umsetzungsregister. Sie ersetzt nicht die ausführlichen Kapitel, hilft aber beim Planen von Issues, Milestones und Abnahmetests.

A.1 Pflichtenmatrix

ID	Pflicht	Version	Grad	Umsetzungshinweis
PF-01	Lokale Windows-Desktop-Anwendung, offline-first, ohne Cloud-Zwang	V1.0	Muss	WinForms/.NET-Anwendung läuft ohne Konto oder Backend.

ID	Pflicht	Version	Grad	Umsetzungshinweis
PF-02	Mehrere unabhängige Tresore	V1.0	Muss	Separate Dateien, separate Master-Passwörter, getrennte Zustände.
PF-03	Internes .svault-Format	V1.0	Muss	Versionierter verschlüsselter Container.
PF-04	Atomisches Speichern	V1.0	Muss	Temp-Datei, kontrolliertes Ersetzen, keine Halbspeicherung.
PF-05	Verschlüsselte Backups	V1.0	Muss	Backup beim Überschreiben, keine Klartextkopien.
PF-06	Dirty-State und Datenverlustschutz	V1.0	Muss	Nachfragen bei Neu, Öffnen, Beenden.
PF-07	EntryTypes Mindestumfang	V1.0	Muss	Login, Database, Mail, Hosting, FTP/SFTP, Server, API, License, SecureNote, Custom, HTTPS/TLS-Zertifikat.
PF-08	CustomFields mit Secret-Markierung	V1.0	Muss	Strukturierte Zusatzfelder, maskierbare Secrets.
PF-09	Gruppen und Untergruppen	V1.0	Muss	Hierarchie mit Root-Knoten und Zyklen-Schutz.
PF-10	Tags	V1.0	Muss	Normalisierung, Anzeige, Suche, Filterbasis.
PF-11	Case-insensitive Suche	V1.0	Muss	Über wichtige Felder und nicht-geheime Zusatzfelder.
PF-12	Typ- und Tagfilter	V1.0/V1.x	Soll	Zur Alltagstauglichkeit im wachsenden Tresor.
PF-13	Kontextmenüs	V1.0	Muss	Gruppen- und Eintragsaktionen ohne Button-Überladung.
PF-14	Drag-and-Drop Einträge	V1.0	Muss	Einträge zwischen Gruppen verschieben.
PF-15	Drag-and-Drop Gruppen	V1.0	Muss	Mit Schutz gegen Drop auf sich selbst/Untergruppen.
PF-16	Sichere Secret-Anzeige	V1.0	Muss	Standardmaskierung, Reveal nur explizit.
PF-17	Clipboard-Autoclear	V1.0	Muss	Zentraler Schutz für sensible Copy-Aktionen.
PF-18	Auto-Lock	V1.0	Muss	Sperre nach Inaktivität.
PF-19	Passwortstärke-Warnung	V1.0	Muss	Vor schwachen Master-Passwörtern warnen.
PF-20	Passwortgenerator	V1.0	Muss	Starke Kennwörter erzeugen und übernehmen.

ID	Pflicht	Version	Grad	Umsetzungshinweis
PF-21	Master-Passwort ändern	V1.x	Muss	Re-Verschlüsselung nach Validierung des alten Passworts.
PF-22	Generatorprofile	V1.x	Soll	Konfigurierbare Profile ohne Default-Passwörter.
PF-23	Eintragsvorlagen	V1.x	Soll	Vorlagen für technische Typen inklusive Zertifikat.
PF-24	HTTPS/TLS-Zertifikat EntryType	V1.0	Muss	Eigener Typ mit Zertifikatsfeldgruppe.
PF-25	Zertifikatsmetadaten	V1.0	Muss	Domain/CN, SANS, Issuer, Serial, Fingerprint, ValidTo.
PF-26	Sensible Zertifikatsfelder	V1.0	Muss	PFX-Passwort, Key-Passphrase, private Schlüssel maskiert.
PF-27	Zertifikatssuche	V1.0	Muss	Domain, SANS, Issuer, Deployment-Ziel auffindbar.
PF-28	Zertifikatsablauf-Warnungen	V1.x	Soll	Warnliste und Schwellwerte.
PF-29	Zertifikatsdatei-Anhänge	V2	Kann/Soll	Verschlüsselte Anhänge für CRT/PFX/Chain.
PF-30	Zertifikatsparser	V2	Kann/Soll	Lokales Auslesen aus PEM/CRT/PFX.
PF-31	ACME-/PKI-Automation	V3/später	Optional	Separates Sicherheits- und Betriebskonzept.
PF-32	.psafe3-Import	V1.0	Muss	Reader, Mapper, Assistent, Bericht.
PF-33	.psafe3-Export	V1.x/V2	Kann/Soll	Nur mit Verlusthinweisen.
PF-34	CSV-Export	V2	Kann	Nur mit Warnung.
PF-35	Browser-Import	V3/später	Optional	Datenschutz und Plattformabhängigkeit separat prüfen.
PF-36	Keine Secrets in Logs	V1.0	Muss	Redaction-Regeln und Tests.
PF-37	MRU-Liste ohne Secrets	V1.0	Muss	Nur Dateipfade/Anzeigenamen, kein Passwort.
PF-38	Dateisperren/Zweitöffnung	V1.0/V1.x	Soll	Konservative Konfliktbehandlung.
PF-39	Integritätsprüfung Programmdateien	V1.x	Kann/Soll	Begrenzter Schutz, ehrlich dokumentiert.
PF-40	Eigenes Icon	V1.x	Soll	Produktreife und Wiedererkennbarkeit.
PF-41	Mehrsprachigkeit DE/EN	V2	Soll	Ressourcen vorbereitet, nicht V1-kritisch.
PF-42	Hell-/Dunkelmodus	V2	Kann/Soll	UX-Ausbau.

ID	Pflicht	Version	Grad	Umsetzungshinweis
PF-43	TOTP	V2	Kann/Soll	Komfort gegen Faktorentrennung abwägen.
PF-44	Passkeys	V3/später	Optional	Separates Konzept.
PF-45	Recovery ohne Backdoor	V2/später	Konzept	Nur explizit vorbereitet, nie versteckt.
PF-46	Unit-/Integrationstests	V1.0	Muss	Domain, Application, Security, Storage, Interop.
PF-47	Manuelle QA-Liste	V1.0	Muss	End-to-End-Abnahme.
PF-48	Dokumentation synchron halten	V1.0	Muss	README, Lastenheft, Pflichtenheft, Architektur, ADRs.

Anhang B - Vorgeschlagene Umsetzungspakete bis V1.0

B.1 Milestone-Vorschlag

Milestone	Ziel	Abnahmekern
M12	Clipboard-Schutz und Secret-Komfort	Sensitive Copy-Aktionen laufen zentral, Auto-Clear funktioniert, Statusfeedback vorhanden.
M13	Dirty-State und Datenverlustschutz	Neu/Öffnen/Beenden fragen bei ungespeicherten Änderungen sauber nach.
M14	Lock/Auto-Lock	Tresor sperrt nach Inaktivität; Entsperren mit Master-Passwort.
M15	Passwortgenerator	Generator-Dialog erzeugt starke Passwörter und übernimmt sie sicher.
M16	HTTPS/TLS-Zertifikatseintrag	EntryType, Detailansicht, Editierdialog, Suche und Tests für Zertifikatsfelder.
M17	Backup/Restore-Härtung und Dateikonflikte	Backup-Strategie sichtbar, Fehlerfälle verständlich, keine Halbspeicherung.
M18	Suche und Filter alltagstauglich	Typ-/Tagfilter, Zusatzfeldsuche, Zertifikatssuche.
M19	Password-Safe-Import	Reader, Mapping, Import-Assistent, Importbericht.
M20	Release-Härtung	Tests grün, Doku aktuell, Security-Review, manuelle Abnahmeliste.